

Coding & Solution

Phase 5 · Project Development Phase

Arockia Rajamanickam (Team Lead) · John Richardson Dyriaraj C · Saravana Kumar S · Balaji S · Geethesh B S

This document presents the core solution of the Script-Controlled ACL project: four record-level Access Control rules on the custom table `u_institution_details` that together restrict access by the user's role and by the Branch field value, plus the server-side GlideScript that enforces the scripted admin override on read. All four rules were edited after elevating to the `security_admin` role.

The four Access Control rules

Operation	Requires role	Advanced	Condition	Script
Read	bb1	Yes	Branch is EEE (<code>u_branch=EEE</code>)	Returns true for admin, true for bb1, false for everyone else
Create	bb2	No	None	None
Write	bb3	No	None	None
Delete	bb4	No	None	None

READ ACL script

The Read ACL is set to Advanced and runs the following server-side GlideScript in its Script field:

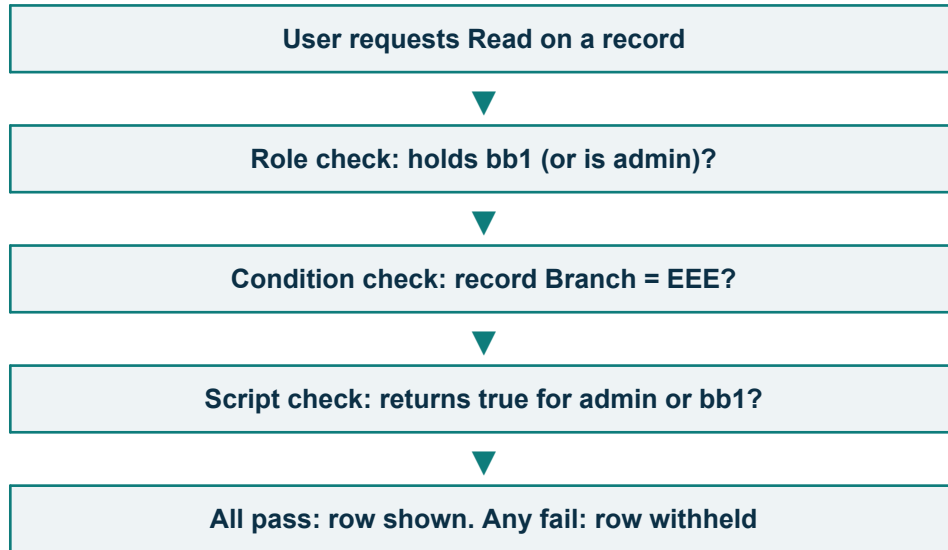
```
(function(){ if (gs.hasRole('admin')) { return true; } if (gs.hasRole('bb1')) { return true; } return false; }());
```

The self-invoking function checks the caller's roles with `gs.hasRole`. It returns true immediately for any admin, returns true for holders of bb1, and otherwise returns false. Wrapping the logic in an immediately-invoked function keeps the Advanced field to a single expression whose value is the final allow or deny decision, and keeps the admin override explicit and auditable in one place.

How role, condition and script combine

ServiceNow evaluates a matching ACL as a logical AND of its parts. For a user to be granted an operation on a record, the ACL that matches that operation and table must pass every check it defines. If any single part fails, the ACL denies, and the record row (or the whole list) is withheld.

- Role gate: the caller must hold the required role. For Read the role is bb1, so a user without bb1 fails the Read ACL at the role check.
- Condition gate: the data condition `u_branch=EEE` means the rule only permits records whose Branch value is EEE, so records for ECE or CSE are not returned to a bb1 user through this rule.
- Script gate: the Advanced script must also return true, which happens only for admin or bb1, giving one explicit and auditable override point.
- Combined effect: the three checks are ANDed together, so a bb1 user sees only EEE records; a user with no bb roles matches no permitting ACL and is blocked with 'Security constraints prevent access'; the System Administrator bypasses the row condition and sees every record, while the script's explicit admin branch keeps that override intentional.



Evidence (from the ServiceNow instance)

The screenshot shows the configuration for an Access Control rule named 'u_institution_details'. The rule is configured with the following settings:

- * Type: record
- * Operation: read
- Application: Global
- Active: ☒
- Advanced: ☒
- Admin overrides: ☒
- Decision Type: Allow If
- Protection policy: -- None --
- * Name: Institution Details [u_institution_details]
- Description: Allow read for records in u_institution_details, for users with role bb1, and if the ACL script returns true, and if the ACL condition (u_branch=EEE) evaluates to true.

Conditions

Access Control Rules have two decision types, and these types will behave differently depending on conditions.

1. Allow Access: Allows access to a resource if all conditions are met. Additional ACLs may grant access to records where this ACL has not granted access.
2. Deny Access: Denies access to a resource unless all conditions are met. Additional ACLs may not grant access to records where this ACL has denied access.

[More Info](#)

Requires role

Role
bb1
Insert a new row...

Security Attribute Condition

READ ACL: role bb1, condition and script

This XML file does not appear to have any style information associated with it. The document tree is shown below.

```
<?xml>
<sys_security_acl>
  <active>true</active>
  <admin_overrides>true</admin_overrides>
  <advanced>true</advanced>
  <applies_to_table>"u_institution_details">
  <condition table="u_institution_details">
    u_branch=EEE
    <item gate="false" or="false" field="u_branch" endquery="false" value="EEE" operator="=" newquery="false"/>
  </condition>
  <controlled_by_refs/>
  <decision_type>allow</decision_type>
  <description>Allow read for records in u_institution_details, for users with role bbl, and if the ACL script returns true, and if the ACL condition (u_branch=EEE) evaluates to true.
  </description>
  <local_or_existing>Existing</local_or_existing>
  <name>u_institution_details</name>
  <operation>read</operation>
  <script>
    <[[CDATA[ (function () {
      // Allow admin users full access
      if (gs.hasRole('admin')) {
        return true;
      }
      // Allow only EEE branch users to see EEE records
      if (gs.hasRole('bbl')){
        return true;
      }
      // Deny access for all others
      return false;
    }]]>
  </script>
  <security_attribute/>
  <sys_class_name>sys_security_acl</sys_class_name>
  <sys_created_by>admin</sys_created_by>
  <sys_created_on>2026-09-28 07:15:11</sys_created_on>
  <sys_id>179ff7d293e3471068e435018bba10a5</sys_id>
  <sys_mod_count>4</sys_mod_count>
  <sys_name>u_institution_details</sys_name>
  <sys_package>global</sys_package>
  <sys_policy/>
  <sys_scope>global</sys_scope>
  <sys_update_name>sys_security_acl_179ff7d293e3471068e435018bba10a5</sys_update_name>
  <sys_updated_by>admin</sys_updated_by>
  <sys_updated_on>2026-09-28 07:46:08</sys_updated_on>
  <type>record</type>
</sys_security_acl>
</xml>
```

READ ACL XML: advanced, u_branch=EEE, script